The Economics of Cybersecurity

Canonical Models of Security Investment

Lecture 2: From one firm to many

Dana Etgar-Itzhaki
Sample lecture

© 2026 Dana Etgar-Itzhaki. All rights reserved. These slides may be used for personal study only and may not be reproduced, distributed, or modified without the author's written permission.

Two questions for today

1. **One firm.** How much should a firm invest in protecting its information?
2. **Many firms.** What happens when a firm's security depends on what others do?

Three canonical models

- Gordon and Loeb (2002): optimal investment by a single firm
- Varian (2004): security as a public good
- Kunreuther and Heal (2003): interdependent security

Gordon and Loeb (2002): setup

A firm holds an information set that may be breached.

- L: the loss if a breach occurs
- $v \in (0,1)$: **vulnerability**, the probability of a breach without additional investment
- $z \geq 0$: investment in security
- $S(z,v)$: the probability of a breach after investing z

Assumptions: $S(0,v) = v, \quad S(z,0) = 0, \quad S_z < 0, \quad S_{zz} > 0$

Investment reduces the probability of a breach, but at a decreasing rate.

The original model also includes the probability of an attack; it is normalized to one here.

The firm's problem

The firm maximizes the expected net benefit of its investment:

$$\text{ENBIS}(z) \;=\; \big[\, v - S(z,v) \,\big]\, L \;-\; z$$

First-order condition:

$$-\, S_z(z^*, v)\, L \;=\; 1$$

The marginal reduction in expected loss equals the marginal dollar spent.

Class I

$$S^I(z,v) = \frac{v}{(\alpha z + 1)^\beta}$$

$$z^* = \frac{(v\beta\alpha L)^{1/(\beta+1)} - 1}{\alpha}$$

Class II

$$S^{II}(z,v) = v^{\alpha z + 1}$$

Here α and β measure how productive security investment is.

Two results

Result 1: the 1/e rule

For both classes, the optimal investment never exceeds about 37% of the expected loss:

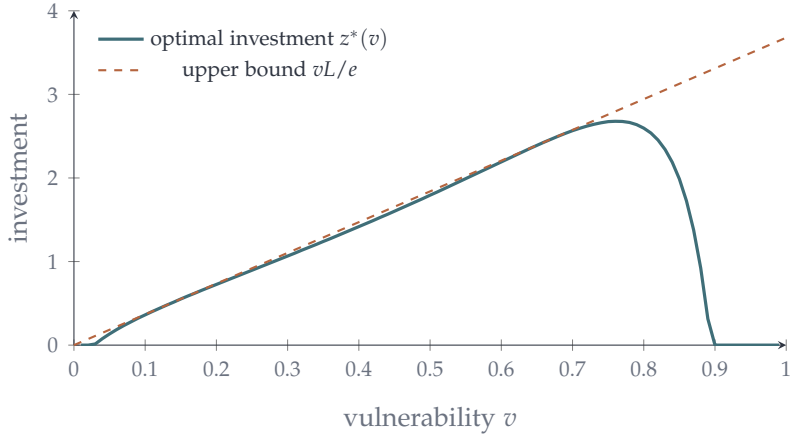
$$z^* \;<\; \tfrac{1}{e}\,vL \;\approx\; 0.37\,vL$$

Result 2: do not always protect the most vulnerable systems

For Class II, optimal investment first rises and then falls with vulnerability. When a system is extremely vulnerable, each dollar buys very little protection, and it may be optimal to invest less, not more.

Intuition: security has diminishing returns. Protecting a system completely is rarely worth its cost.

Optimal investment and vulnerability (Class II)



Numerical example: $S^{II}(z, v) = v^{\alpha z+1}$ with $\alpha = 1$ and $L = 10$, solved by direct maximization of ENBIS.

From one firm to many: security as a public good

In many systems, security is produced jointly. Varian (2004) asks how the **structure** of the system shapes incentives.

Structure	Security depends on	Example
Total effort	$\sum_i x_i$	Shared infrastructure maintained by many
Weakest link	$\min_i x_i$	A network breached via its least protected device
Best shot	$\max_i x_i$	Finding a vulnerability: one discovery is enough

Each agent i chooses effort x_i at a private cost, but the benefit depends on everyone's effort.

Equilibrium: who protects the system?

- **Total effort.** Effort is a perfect substitute across agents. In equilibrium, only the agent with the highest benefit-to-cost ratio contributes; all others free ride.
- **Weakest link.** The least motivated agent sets the level of security for everyone. Others have no reason to exceed it.
- **Best shot.** Typically one agent exerts effort and the rest free ride.

The common lesson

In all three structures, equilibrium security is generally below the social optimum, because each agent ignores the benefit of its effort to others. The structure determines *who* sets the level of security, and therefore where policy should intervene.

Interdependent security: Kunreuther and Heal (2003)

Motivation: in 1988, a bomb loaded onto a plane in Malta was transferred through Frankfurt onto Pan Am flight 103. Each airline's safety depended on the screening of others. **A simple model with two firms**

- Each firm can invest c to protect itself against a direct breach, which occurs with probability p and causes loss L.
- An unprotected firm that is breached infects the other firm with probability q.
- Protection does *not* protect against infection from the other firm.

The game: expected costs

	Firm 2 invests	**Firm 2 does not invest**
Firm 1 invests	c	$c + pqL$
Firm 1 does not invest	pL	$pL + (1-p)\,pqL$

Firm 1's expected cost; the game is symmetric.

- If the other firm invests, investing is optimal when $c < pL$.
- If the other firm does not invest, investing is optimal only when $c < pL(1-pq)$.

Result

When $pL(1-pq) < c < pL$, there are **two equilibria**: both invest, or neither does. The other firm's failure to protect reduces my incentive to protect.

Exercise

Let $p = 0.1$, $L = 100$, and $q = 0.5$.

1. Compute the thresholds pL and $pL(1 - pq)$.
2. For $c = 8$, find all equilibria. Is investment a dominant strategy?
3. For $c = 9.7$, find all equilibria. Which one is socially preferable?
4. Suppose a regulator can subsidize one firm's investment. How large must the subsidy be to rule out the bad equilibrium?

Hint: when one firm is known to invest, what is the other firm's best response?

Policy implications

- **Coordination.** When multiple equilibria exist, moving a few key players can tip the whole system to the good equilibrium.
- **Liability and standards.** Requiring a minimum level of protection addresses the weakest link directly.
- **Insurance.** Premiums that reward protection can restore the incentive to invest, but correlated risk is hard to insure.
- **Subsidies.** Targeting the agents whose effort matters most for others.

Discussion: which of these tools fits a world in which most firms rely on the same few software vendors?

Summary and next lecture

- A single firm should invest in security up to the point where the marginal reduction in expected loss equals its cost, and rarely more than about 37% of the expected loss.
- When security is produced jointly, free riding leads to underinvestment, and the structure of the system determines who sets the level of security.
- Interdependence can create multiple equilibria: insecurity is partly self-fulfilling.

Next lecture: markets for vulnerabilities. Who should find software flaws, and who should pay for them?

Readings

- Gordon, L., and Loeb, M. (2002). The economics of information security investment. *ACM Transactions on Information and System Security*, 5(4), 438–457.
- Varian, H. (2004). System reliability and free riding. In L. J. Camp and S. Lewis (eds.), *Economics of Information Security*, Springer, 1–15.
- Kunreuther, H., and Heal, G. (2003). Interdependent security. *Journal of Risk and Uncertainty*, 26(2–3), 231–249.